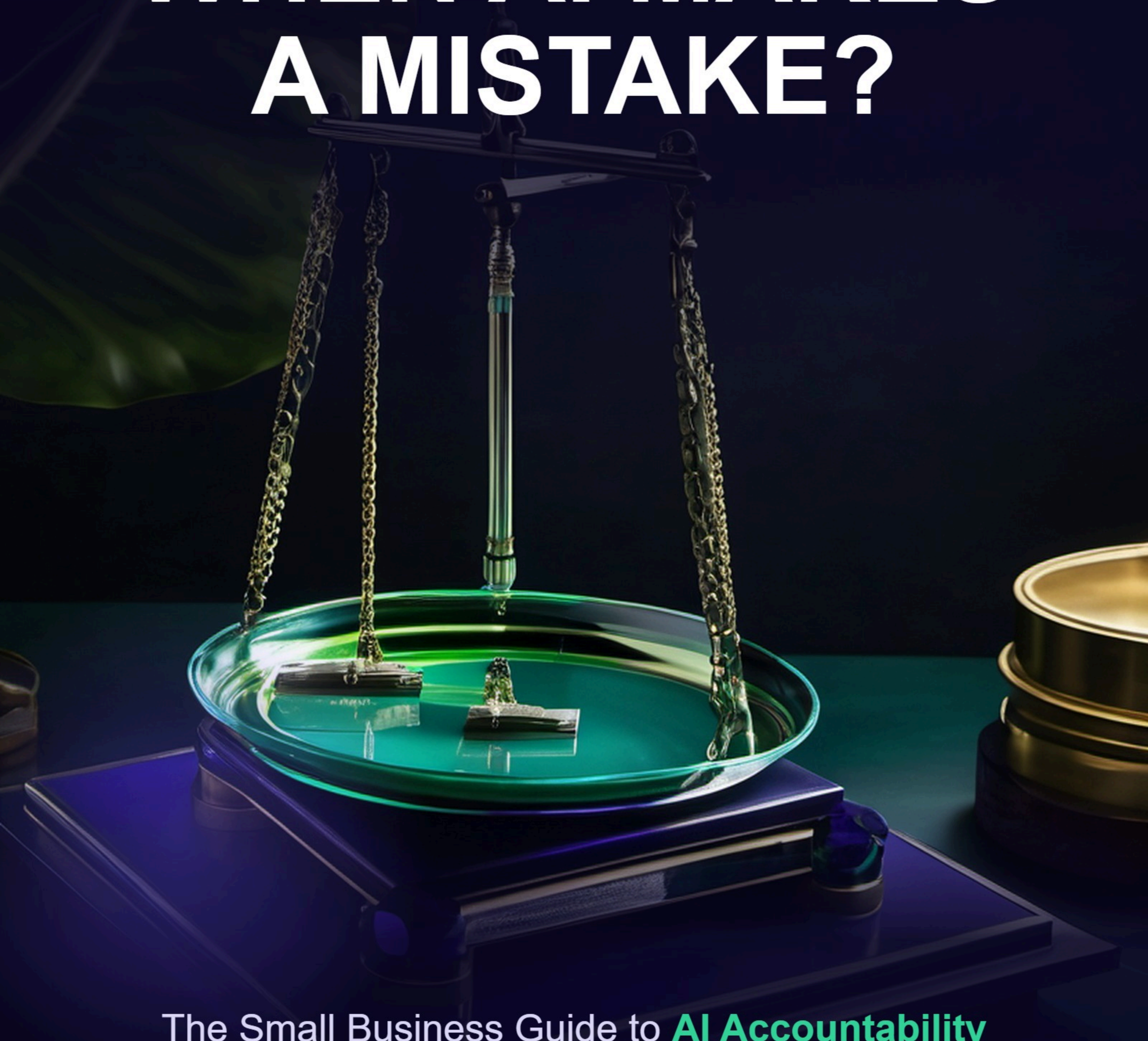
THE QUESTION EVERY BUSINESS WILL FACE

WHO IS RESPONSIBLE WHEN AI MAKES A MISTAKE?



The Small Business Guide to **AI Accountability**

HUMAN OVERSIGHT · AI DECISIONS · COMPLAINTS · GOVERNANCE

ZIRLANDIA MILKOVIC

THE QUESTION EVERY BUSINESS WILL FACE

WHO IS RESPONSIBLE WHEN AI MAKES A MISTAKE?

The Small Business Guide to AI Accountability

ZIRLANDIA MILKOVIC

Who Is Responsible When AI Makes a Mistake?
The Small Business Guide to AI Accountability

© 2026 Zirlandia Milkovic. All rights reserved. No part of this book may be reproduced without written permission, except for brief quotations in reviews.

First edition, 2026. Research cut-off: 30 October 2026. British English. Companion resource: GDPRGard.eu.

This book is practical guidance, not legal, security or data-protection advice. All examples, businesses and people in worked scenarios are fictional.

Contents

START HERE

Educational Disclaimer 4
Introduction: The Question Nobody Asks Until It Is Too Late 4
Who This Book Is For 6
How to Use This Book 6
The One-Page Accountability Check 7

CHAPTERS

1. The Accountability Gap 9
2. What "Responsible" Means in Law 13
3. Know Where AI Makes Decisions 19
4. Human Oversight That Actually Works 24
5. AI-Generated Decisions About People 30
6. Customer Complaints Involving AI 36
7. Vendors, Contracts and the Blame Game 41
8. Governance for Small Businesses 46
9. When the AI Gets It Wrong: Incident Response 50
10. Records, Evidence and Insurance 54
11. Your 30-Day AI Accountability Plan 58
12. Five Case Files 61

CLOSING

Conclusion: Answerable 64

APPENDICES

Appendix A: AI Use Register 65
Appendix B: Decision Risk Sheet 66
Appendix C: Human Review Log 67
Appendix D: One-Page AI Policy Template 68
Appendix E: AI Complaint Record 69
Appendix F: AI Vendor Questionnaire 70
Appendix G: AI Incident Log 72

BACK MATTER

Glossary 73
A Note on GDPRGard.eu 74
About the Author 75
Notes and Sources 76

Educational Disclaimer

This book is practical, educational guidance for small and medium-sized businesses. It is not legal, insurance, audit or data-protection advice, and it does not create a professional relationship between the author and the reader.

Liability, consumer law, employment law, data-protection law and the EU AI Act differ by country, apply differently to different businesses, and are changing quickly. Check the current position with a qualified adviser, your insurer or your regulator before relying on anything here for a decision that matters, especially one that affects a person's job, credit, money or health.

Following the steps in this book may reduce your risk. It cannot guarantee that an AI tool will not make a mistake, that a mistake will not cost you money, or that you will meet every legal duty. Checklists, clause lists and policy templates are starting points to adapt, not finished legal documents.

Every business, person and product used in a worked example is **fictional** and is labelled as such. Where the book describes a real case or rule, it is sourced in the notes at the back. Where it gives a recommendation, it says so.

Introduction: The Question Nobody Asks Until It Is Too Late

Sooner or later, an AI tool in your business will get something wrong.

It will tell a customer something that is not true. It will draft a letter with an invented figure in it. It will rank a job applicant lower for a reason nobody can explain, flag an honest customer as a fraud risk, or

summarise a contract and miss the one clause that mattered. The tool will not apologise, will not be fined and will not turn up to the meeting. It will not be sued. Somebody else will have to answer.

So the question is not whether AI will make a mistake in your business. The question is **who is responsible when it does**, and whether you decided the answer in advance or are about to find out the hard way.

Most small businesses have not decided. AI arrived the way every useful tool arrives: someone tried it, it saved time, and it spread. There is a chatbot on the website, a writing assistant in the inbox, a screening feature inside the recruitment software, a fraud filter inside the payment system. Nobody sat down and said, *this tool may make decisions that affect customers and staff, and this person is accountable for it.*

This book helps you have that conversation. It is built on one plain idea that runs through every chapter:

> **The rule.** AI can produce the output. It cannot carry the responsibility. A named human being in your business always does.

That is not only good practice. In the cases that have reached courts and regulators so far, it is how the law has tended to treat things. A company that puts a tool in front of customers is usually treated as speaking through it. An employer that uses software to make decisions about people is usually treated as the one who made them.

The good news is that accountability does not require an AI lab, a legal department or a six-figure governance programme. For a business of five, fifty or two hundred people it comes down to a few habits: **know where AI is used, decide who owns each use, put a real human check where it matters, handle complaints properly, keep a record, and learn from every mistake.** You can build all of it with a spreadsheet, a one-page policy and an hour a week.

The book follows that order. You will map where AI touches your business, learn what the law expects of you, design human oversight that is more than a rubber stamp, deal with automated decisions about

people, handle customer complaints, set up your supplier contracts, write a simple governance framework, prepare for incidents, and finish with a 30-day plan and five fictional case files to practise on.

You do not need to fear AI to use this book. Used well, it is one of the most useful tools a small business has ever been handed. The aim is only to make sure that when it slips, you are the one who is ready.

Who This Book Is For

This book is for you if you run, manage or advise a small or medium-sized organisation in Europe or the UK and any of the following is true:

- You use an AI chatbot, writing assistant, image tool, transcription tool or recommendation feature, and you are not certain who checks what it produces.
- AI features are built into software you already pay for, such as accounting, recruitment, customer support, marketing or payments, and you did not choose or configure them yourself.
- Staff use AI tools on their own initiative, and you suspect you do not know all of them.
- A customer has complained, or might complain, about something an AI tool said or decided.
- You need to answer an insurer, a client, a lender or a regulator who is starting to ask how you control your AI use.

It is written for owners, managers, operations leads, HR leads, customer-service leads and the person who has been quietly handed "the AI thing". It assumes no technical background. Technical terms are explained when they first appear and collected in the glossary.

It is **not** for organisations building high-risk AI systems for sale, which face much heavier duties under the AI Act. If you are one, treat this book as an introduction and take specialist advice.

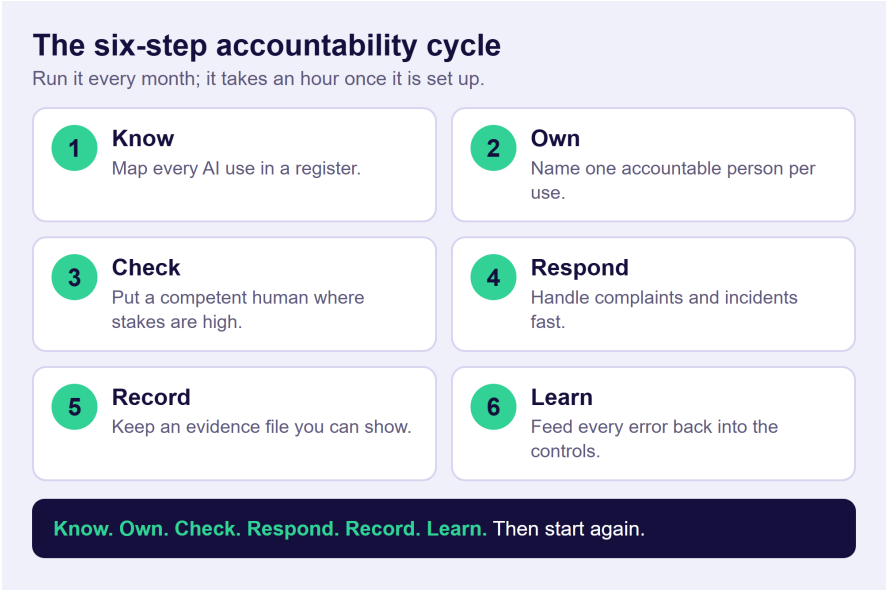
How to Use This Book

You can read the book front to back in an evening, or use it as a manual. Chapters 1 and 2 explain why accountability matters and what the law expects. Chapters 3 to 6 are the practical core: **map**, **oversee**, **decide**, **respond**. Chapters 7 to 10 cover suppliers, governance, incidents and evidence. Chapter 11 is a 30-day plan and Chapter 12 gives you five fictional case files to practise on.

Look for these markers:

- **The rule.** A principle worth remembering, set in a dark panel.
- **Fictional.** A worked example using invented people and businesses.
- Check boxes (☐). A step you can tick off. Where a line is blank, write on it.

The appendices contain ready-to-use templates: an AI use register, a decision risk sheet, a human review log, a one-page AI policy, a complaint record, a supplier questionnaire and an incident log. Copy them into a spreadsheet or print them.



The six-step accountability cycle used in this book

The One-Page Accountability Check

Before you switch on a new AI feature, or renew an existing one, ask these questions. If you cannot answer one, that is your next task.

- ☐ What will this tool produce or decide, and who will see or be affected by it?
- ☐ Could a wrong output harm a person's money, job, health, rights or reputation?
- ☐ Who in our business is **named** as the owner of this use?
- ☐ What human check happens before the output reaches a customer or becomes a decision, and does that person have the time, knowledge and authority to say no?
- ☐ Does the tool use personal data, and have we told people and checked the legal basis?
- ☐ Will customers know they are dealing with AI where they should?
- ☐ What does our contract with the supplier say about errors, data and liability?
- ☐ How will a customer or employee complain about an AI decision, and how will we fix it?
- ☐ What will we log, so we can show what happened and why?
- ☐ What is the "off switch", and who is allowed to press it?

CHAPTER 1

The Accountability Gap



> **Fictional.** Tidewell Home Goods, its chatbot "Willow" and every person below are invented for teaching. They are not real businesses or incidents.

Tidewell Home Goods is a twelve-person online shop selling kitchenware and linen. Eight months ago the owner, Priya, added a chatbot called Willow to the website. It was cheap, it took ten minutes to set up, and it answered the same fifty questions that used to fill the shared inbox. Nobody reviewed what Willow was allowed to say. Nobody was told to.

On a Thursday evening a customer asks Willow whether she can return a duvet she bought six weeks ago. Tidewell's policy is thirty days. Willow replies, in a friendly tone, that returns are accepted "within 90 days for any reason, with a full refund, including shipping". It sounds official. It is wrong, and nothing on the page says so.

The customer returns the duvet and the shipping costs her fifteen pounds. The refund request lands on the customer-service desk. The agent, Tom, says the policy is thirty days and refuses. She sends Tom a screenshot. The conversation escalates, then appears in a review, then in a social-media post with eleven thousand shares.

Priya has three questions. *Did we promise that? Do we have to pay? And whose fault is it?*

The honest answers are: probably yes, probably yes, and hers. The chatbot did not decide to promise anything. A tool that Tidewell chose, configured and put in front of customers produced a sentence, and the

customer relied on it. Nobody at Tidewell had written down who was in charge of what Willow said.

That gap, between what an AI tool does and who answers for it, is the **accountability gap**. This book is about closing it.



A shop floor, a screen, and a question about who answers

It has already happened to real businesses

The story above is invented, but the pattern is not. A handful of widely reported cases show how quickly "the AI said it" fails as a defence:

- **Air Canada (2024).** A customer asked the airline's website chatbot about bereavement fares and was told he could apply retrospectively. The airline's staff later said he could not. A Canadian tribunal ordered the airline to pay him the difference, rejecting the suggestion that the chatbot was a separate entity responsible for its own statements. The sums were small. The reasoning was not.[1]
- **DPD (2024).** After a software update, a parcel company's customer-service chatbot was coaxed by a customer into swearing and criticising the company. It was widely shared. The company disabled the AI element and said it was updating the system.[2]
- **A car dealership (2023).** A dealership's chatbot was prompted into "agreeing" to sell a vehicle for one dollar. It was not a binding sale, but it showed how easily an unsupervised chatbot can be made to say things the business never intended.[3]

- **Lawyers and fabricated cases (2023).** Lawyers in a US federal case filed a brief containing case citations an AI tool had invented. The court sanctioned them. The excuse that the tool had produced the text did not help.[4]
- **A consultancy report (2025).** A large consultancy partly refunded a government client after a report it delivered was found to contain AI-generated errors, including fabricated references.[5]

None of these businesses set out to mislead anyone. In each case the output of a tool was treated as the business's own.

> **The rule.** If your business puts an AI output in front of a customer, a regulator or a court, you own it, whether a person or a machine typed it.

Why the gap opens

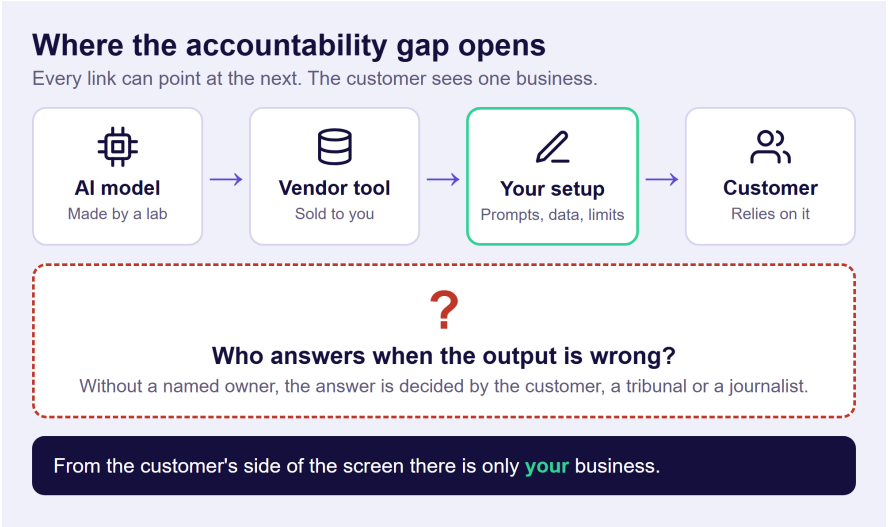
The accountability gap rarely comes from carelessness. It comes from four ordinary pressures.

1. The tool is easy to adopt. Many AI tools need no procurement, no IT project and no budget approval. A person with a credit card can add a chatbot, a transcription service or a screening plug-in in an afternoon. The decision to use it was made informally, so no one was made the owner.

2. The output looks finished. Fluent, confident AI text feels checked. It is not. A tool can be fluent and wrong in the same sentence, and it will present both in the same tone.

3. Responsibility is split across suppliers. A model maker, a software vendor, an integrator and your own staff may all touch one output. Each can point at the next. From the customer's side of the screen there is one business: yours.

4. Nobody owns the consequences. The person who benefited from the speed is rarely the person who answers for a complaint three weeks later.



Where the accountability gap opens

What this book will and will not do

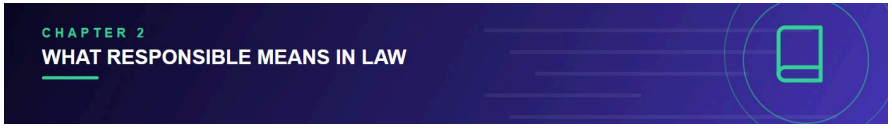
This book will not tell you that AI is dangerous or that you should avoid it. It will not turn you into a lawyer. It will help you do five practical things:

1. **Know** where AI is used in your business and what it affects.
2. **Assign** a named owner to each use.
3. **Check** outputs with a human who can actually say no, where the stakes justify it.
4. **Respond** properly when a customer or employee complains.
5. **Record** enough to show what happened and what you did about it.

If you can do those five things, you will be ahead of most businesses of any size.

CHAPTER 2

What "Responsible" Means in Law



"Responsible" is not one thing. When an AI mistake happens, several different kinds of responsibility can apply at once, to different people, under different rules. Understanding the main kinds helps you decide where to put your effort.

This chapter is a plain-English map, not legal advice. The details differ by country and by situation. The pattern, however, is consistent.

The starting point: you cannot outsource the duty

Across most legal systems, a business is answerable for the way it carries out its activities, including through tools, staff and suppliers. Using AI changes how a task is done. It does not change who is answerable for the result.

You can see this in three places.

- **To your customers**, under contract law and consumer law. What you say to customers, through whatever channel, forms part of what you sell.
- **To the people your decisions affect**, under data-protection law, employment law and equality law. Decisions about people carry duties of fairness, transparency and the ability to challenge.
- **To regulators and the public**, under sector rules and the new AI-specific rules.

Duties to customers

If an AI tool tells a customer something about price, delivery, returns, warranty or suitability, a court or tribunal will usually ask whether a reasonable customer could rely on it, and whether you allowed the tool to speak for you. The Air Canada decision turned on exactly that logic: the company was responsible for all the information on its website, whether it came from a static page or a chatbot.[1]

Consumer-protection law adds to this. In the EU, rules on unfair commercial practices and on consumer contracts are concerned with misleading information, however it is produced, and in the UK the Consumer Rights Act 2015 requires services to be performed with reasonable care and skill.[13] An AI error in advertising, pricing or a refusal to honour a stated right can fall squarely within those rules.

Practical consequence: treat whatever your AI tools tell customers as if a member of staff had written it on company letterhead.

Duties to people affected by your decisions

If AI is used to make or shape a decision about an individual (hiring, firing, credit, pricing, access to a service, a fraud flag), several bodies of law can apply:

- **Data-protection law.** Under the GDPR, the organisation that decides why and how personal data is used is the **controller**, and is responsible for being able to show compliance.[6] If personal data goes into an AI tool, you are very likely the controller of that use. Article 22 gives people specific protections against decisions based solely on automated processing that have legal or similarly significant effects.[14] Chapter 5 covers this.
- **Employment and equality law.** An employer is generally answerable for discriminatory outcomes in its hiring or management decisions, even if software produced them.
- **Sector rules.** Finance, health, insurance, education and housing often have their own requirements for explanations, fairness and records.

Practical consequence: a decision about a person is **your** decision, and you must be able to explain it and correct it.

The EU AI Act: your role as a deployer

The EU's AI Act (Regulation (EU) 2024/1689) sorts organisations by role. The two that matter most here are **providers**, who develop or place AI systems on the market, and **deployers**, who use an AI system under their own authority in a professional context. Most small businesses are deployers.[7]

You do not have to read the whole Act. These points are the ones a small deployer should know:

- **AI literacy.** Since 2 February 2025, providers and deployers must take measures to ensure a sufficient level of AI literacy among staff who operate or use AI systems on their behalf.[9]
- **Transparency.** Rules in Article 50 require, in general terms, that people be told when they are interacting with an AI system, and that certain AI-generated content be marked. The dates for these duties have been the subject of change, so check the current text.[10]
- **High-risk systems.** AI used for things such as recruitment, worker management, access to essential services and credit scoring is classed as "high-risk". Deployers of those systems have duties such as using the system according to its instructions, assigning **human oversight to people with the necessary competence, training and authority**, monitoring operation and keeping logs.[21]
- **Timing.** In July 2026 an amending regulation, the "AI Omnibus", entered into force. It postponed the application of many high-risk obligations, with standalone high-risk systems now due from 2 December 2027 and product-embedded systems from 2 August 2028.[8] A deferral is not a cancellation: the habits you build now are the ones you will need then.

Practical consequence: even before every obligation applies, "assign a competent person, keep logs, tell people they are dealing with AI, and train your staff" is the direction of travel. This book builds those habits in.

Who pays when the product is faulty?

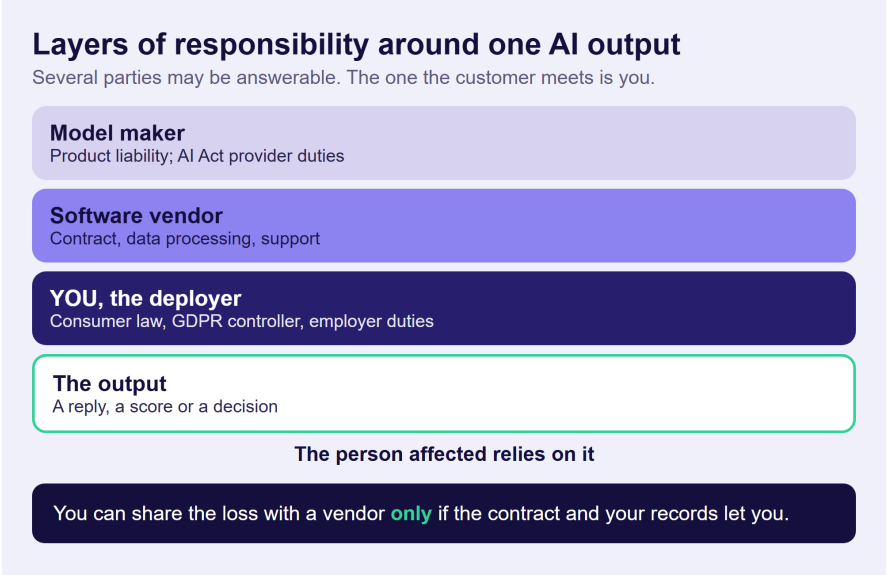
A different question is who bears the loss when an AI product itself is defective. The EU's new Product Liability Directive (Directive (EU) 2024/2853) extends strict product liability to **software, including AI systems**, and to some digital services. Member States must apply it by 9 December 2026, and it applies to products placed on the market after that date.[11] The Commission also dropped its separate proposal for an AI Liability Directive.[12]

For a small deployer, this is mostly good news: it means a customer who is harmed by a defective AI product may have a route against the maker. But it does not make **you** invisible. As the business that decided to use the tool and put it in front of the customer, you can still face claims in contract, consumer law, negligence or data protection. Your contract with the supplier determines whether you can recover the loss from them (Chapter 7).

A simple map of who is responsible for what

Situation	Who customers and regulators will usually look at first	Who you may be able to recover from
Your chatbot gives wrong policy information	You	The supplier, only if the contract allows and the fault was theirs
A staff member sends an unchecked AI draft with an error	You, and the staff member inside your organisation	Usually nobody
AI screening ranks applicants unfairly	You as employer and controller	The supplier, depending on the contract and who configured it
The AI vendor's system fails or is breached	You (as controller) and the vendor	The vendor, under the data-processing agreement and contract
A defective AI product injures someone	The maker, under product-liability rules, and potentially you	The maker or supplier

Situation	Who customers and regulators will usually look at first	Who you may be able to recover from
An employee uses an unapproved tool and leaks data	You, as controller	Possibly the employee, under employment law, with care



Layers of responsibility around one AI output

The four questions a regulator or tribunal will ask

Whatever the legal route, the same four practical questions come up. They are the real test of whether you closed the accountability gap.

1. **Did you know the tool was being used?** (A register shows you did.)
2. **Did you assess the risk and decide it was acceptable?** (A short written risk check shows you did.)
3. **Was there a competent human check, proportionate to the stakes?** (A review log shows it.)
4. **When it went wrong, what did you do?** (An incident log shows it.)

The rule. You will not be judged on whether the AI made a mistake. You will be judged on whether you had sensible controls, and what you did next.

CHAPTER 3

Know Where AI Makes Decisions



You cannot be accountable for something you do not know exists. The first practical step is therefore a simple census: where is AI used in your business, what does it produce, and what happens next?

Most owners are surprised by the result. The visible tools (the chatbot, the writing assistant) are usually the smaller part. The larger part is AI that is **built into** software you already use, and AI that **staff bring in themselves**.

Four places AI hides



The work still lands on a desk, whatever the software does

1. Customer-facing tools. Chatbots, voice assistants, product recommendation, dynamic pricing, automated email replies, AI-written product descriptions, AI-generated images in adverts.

2. Back-office tools. Meeting summaries, transcription, document drafting, contract review, bookkeeping categorisation, invoice reading, forecasting, spam and fraud filters.

3. People-related tools. CV screening and ranking, interview scheduling and scoring, performance dashboards, shift allocation, monitoring and productivity software.

4. Shadow AI. Public AI tools that staff use without telling you, often with the best of intentions: pasting a customer email into a free chatbot to rewrite it, uploading a spreadsheet to summarise it, using an AI browser extension on work accounts.

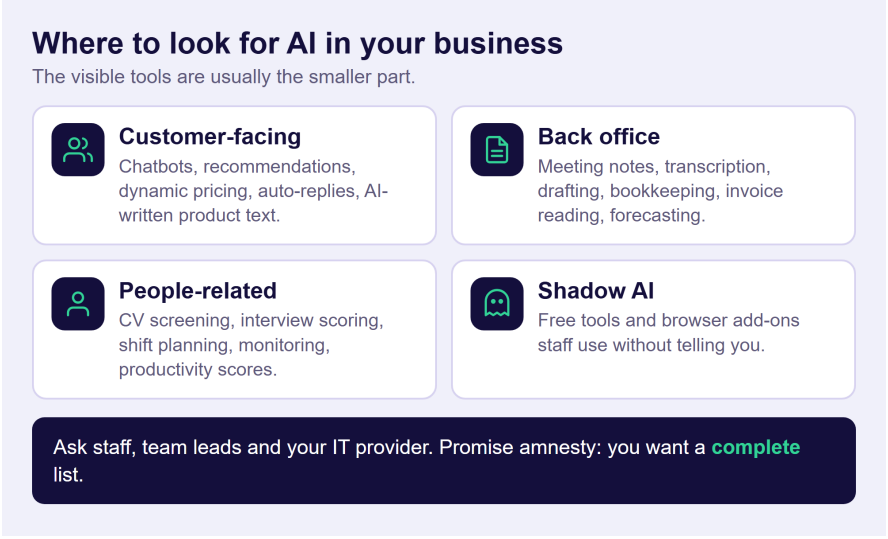
> **Fictional.** At Harbourline Print, a ten-person firm, the owner believed the business used no AI. A one-hour survey found six uses: a chatbot, an AI proofreading plug-in, a meeting transcriber used by two managers, a free image generator, a "smart replies" feature in the email system, and a payment-fraud filter. Three of the six had never been mentioned to the owner.

Build the AI use register

The register is the foundation of everything else in the book. It is a list, not a project. Create it in a spreadsheet with these columns (Appendix A has a ready-made version):

Column	What to write
Tool and supplier	Name, version or plan, who supplies it
Purpose	What task it does
Output	What it produces: text, score, decision, recommendation
Who sees the output	Customers, staff, nobody (internal)
Personal data	None / ordinary / sensitive; whose
Owner	One named person
Human check	What review happens, by whom
Risk tier	Low / Medium / High (see below)
Contract and notes	Contract link, last review date

How to find the uses. Ask three groups three questions. Ask staff: *which AI tools or AI features do you use for work, including free ones?* Ask team leads: *where does the software we pay for use AI to suggest, score or decide things?* Ask your IT provider or check your bank statement: *which subscriptions include* AI? Promise amnesty: the goal is a complete list, not a list of culprits.



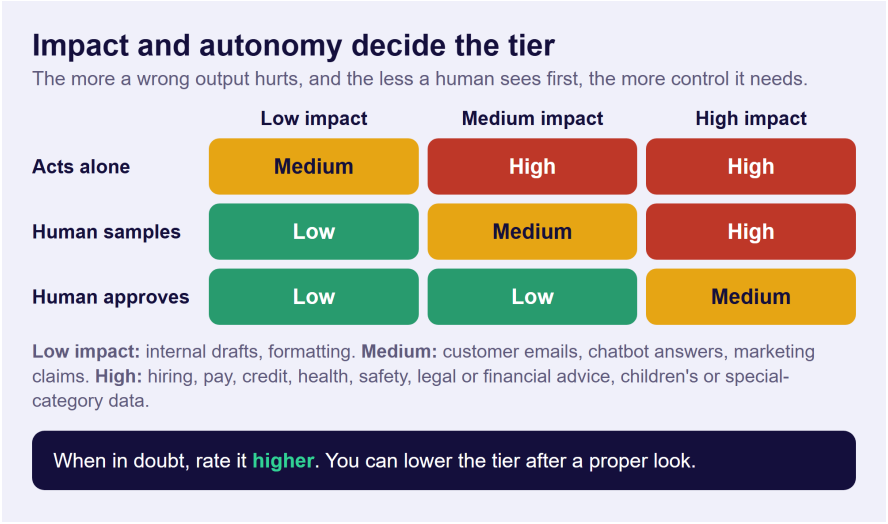
Where to look for AI in your business

Sort uses by what could go wrong

Not every use needs the same effort. A tool that suggests a subject line for a newsletter and a tool that decides whether an applicant gets an interview are very different. Rank each use by **impact** (how badly a wrong output could hurt someone or the business) and **autonomy** (how much happens without a human in the loop).

Tier	Typical uses	What you need
Low	Internal drafting, brainstorming, formatting, summarising non-sensitive material	Basic rules for staff, spot checks
Medium	Customer emails, chatbot answers on ordinary topics, marketing claims, internal analysis used in decisions	Named owner, human review or sampling, complaint route, logging

Tier	Typical uses	What you need
High	Decisions about people (hiring, pay, discipline, credit, access), health or safety advice, legal or financial advice, anything involving special-category data or children	Named senior owner, human decision-maker with authority, written risk assessment, explanation and appeal route, full records



Impact and autonomy decide the tier

When in doubt, rate it higher. You can always lower the tier once you have looked properly.

Three questions that reveal the real risk

For each use in the register, ask:

1. **What is the worst plausible wrong output?** Not the average case. Imagine the tool being confidently wrong at the worst moment.
2. **Who would notice, and when?** If a mistake would reach a customer before any person sees it, the risk is higher.
3. **Can it be undone?** A wrong internal summary can be corrected. A wrongly rejected applicant, a wrongly blocked customer or a promise made in writing is harder to reverse.

> **The rule.** The more a wrong output hurts someone, and the less a human sees before it lands, the more control it needs.

Checklist: your first register

- ☐ I have asked staff, team leads and our IT provider about AI use, including free tools.
- ☐ Every use is in the register with a named owner.
- ☐ Every use has a risk tier.
- ☐ The high-risk uses are flagged and have a date for their first review.
- ☐ Staff know how to add a new tool to the register.

CHAPTER 4

Human Oversight That Actually Works



Almost every guideline on AI says the same thing: keep a human in the loop. Almost every failure story has a human in the loop too. The difference between those two facts is where accountability is won or lost.

Human oversight that exists on paper but not in practice is worse than none, because it gives you a name to blame and the false comfort that someone checked.

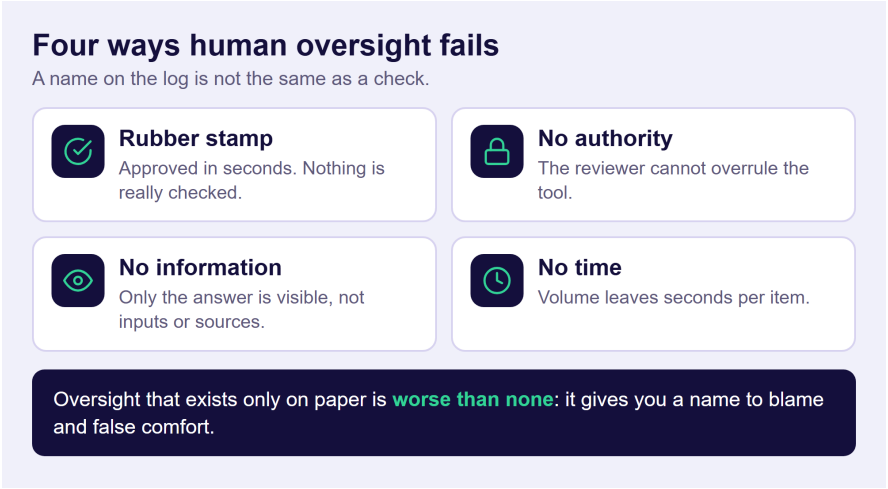
Why people stop checking

Psychologists call it **automation bias**: the tendency to over-rely on an automated suggestion, particularly when it is usually right, and to miss the occasions when it is wrong.[22] The better the tool, the stronger the effect. A reviewer who has approved two hundred correct outputs in a row will not read the two hundred and first with fresh eyes.

Add practical pressure: a long queue, a target of items per hour, a tool that already shows a confident answer. The review becomes a click. Here are the four most common ways that human oversight fails.

Failure	What it looks like	Why it matters
Rubber stamp	The reviewer approves almost everything within seconds	There is no real check. Anything the tool gets wrong goes out.
No authority	The reviewer can approve but cannot reject or change the result without permission	The human is a witness, not a decision-maker.

Failure	What it looks like	Why it matters
No information	The reviewer sees only the answer, not the inputs, the sources or the reasoning	They cannot tell a good answer from a plausible one.
No time	The volume leaves seconds per item	Careful review is physically impossible.



Four ways human oversight fails

Three levels of human involvement



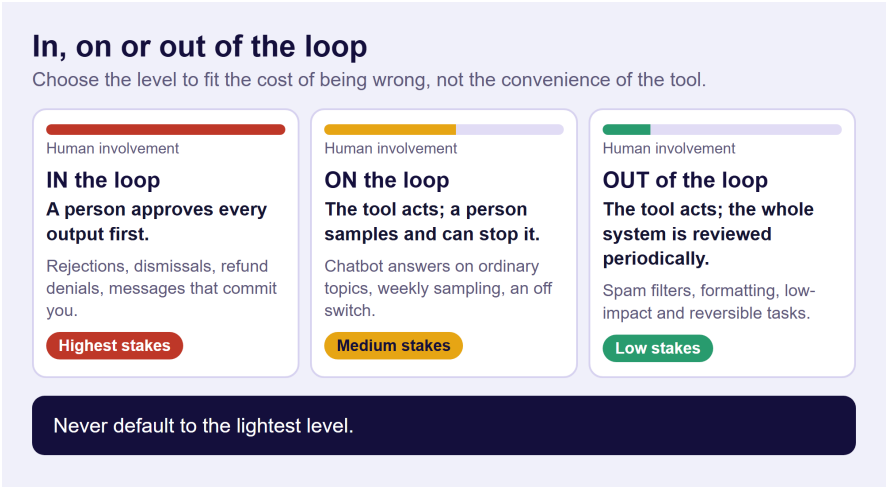
A human checkpoint only works if someone really stands there

Choose deliberately which level fits each use. Do not default to the lightest.

Human in the loop. A person reviews and approves each output before it takes effect. Use it for high-stakes or irreversible things: a rejection, a dismissal, a refund denial, a message that makes a commitment.

Human on the loop. The tool acts automatically, but a person monitors, samples and can intervene. Use it for medium-risk, high-volume work: chatbot replies on ordinary topics, with daily sampling and an easy off switch.

Human out of the loop. The tool acts alone with periodic review of the whole system. Use it only for low-impact uses, such as spam filtering or formatting, where errors are cheap and reversible.



In, on or out of the loop

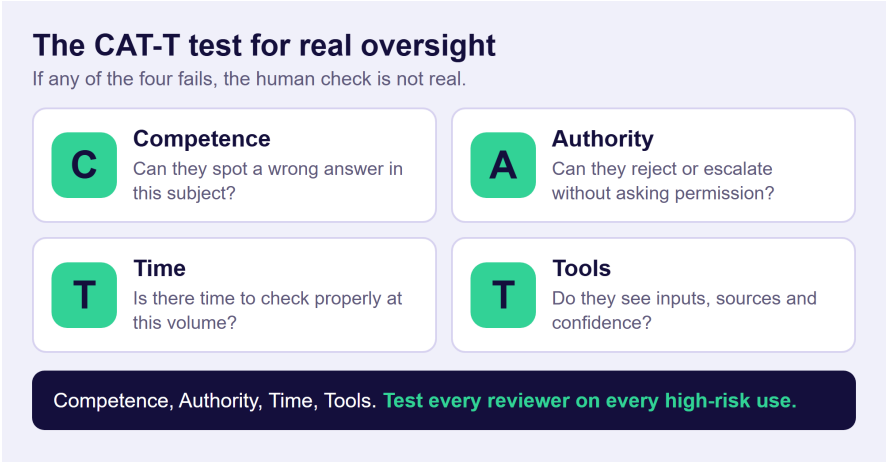
> **The rule.** Match the level of human involvement to the cost of being wrong, not to the convenience of the tool.

Make the oversight real: the CAT-T test

For any use that needs a human check, test the reviewer against four conditions. If any fails, the oversight is not real.

- **C: Competence.** Does the reviewer understand the subject and the tool's typical errors well enough to spot a wrong answer?
- **A: Authority.** Can they reject, change or escalate without having to ask permission or justify themselves?
- **T: Time.** Is there time to do the check properly at the volume involved?
- **T: Tools and information.** Do they see the inputs, the sources and the confidence, and can they check a claim?

The AI Act's expectation for high-risk systems is in the same spirit: deployers must assign human oversight to natural persons who have the necessary competence, training and authority.[21]



The CAT-T test for real oversight

Practical techniques that work

Show the evidence, not just the answer. If the tool cites sources, make the reviewer open at least one. If it produces a score, show what drove it.

Add friction on purpose. For high-risk decisions, require the reviewer to write a one-line reason in their own words before approving. It forces engagement.

Sample and audit. For medium-risk uses, review a fixed sample, for example twenty chatbot conversations a week, and record the error rate. If the rate rises, tighten the controls.

Seed known tests. Occasionally feed in a case with a known wrong answer to see whether reviewers catch it. Treat the result as a training signal, not a disciplinary one.

Rotate and rest. Reviewers who see the same output all day stop seeing it. Rotate tasks and cap review blocks.

Make "no" easy and safe. Reward catching an error. If rejecting the tool's output is treated as slowing the team down, people will stop rejecting it.

Build the off switch. Name who can pause the tool immediately, and test that they can.

Write down what the human is for

For every use that needs oversight, write one sentence in the register: "*[Role] reviews [what] before [what happens], and can [reject / amend / escalate].*" If you cannot complete the sentence, you have found a gap.

> **Fictional.** Kestrel Hotels used an AI tool to draft replies to guest complaints. A duty manager "approved" each reply by pressing a button. The log showed an average of four seconds per approval. After a reply promised a free week's stay to a guest who had asked about a late checkout, the owner replaced the button with a short form: *what is the guest's actual issue, and what are we offering?* Approvals slowed to forty seconds. The invented promises stopped.

Checklist: oversight

- ☐ Every high-risk use has a human decision-maker with authority to overrule the tool.
- ☐ Reviewers pass the CAT-T test (competence, authority, time, tools).
- ☐ Medium-risk uses have a sampling routine and a recorded error rate.

- ☐ Someone is named to pause each tool, and has been shown how.
- ☐ Reviewers are praised, not blamed, for rejecting wrong outputs.

CHAPTER 5

AI-Generated Decisions About People



An AI mistake about a spreadsheet is an irritation. An AI mistake about a person can cost them a job, a loan, a service or their good name. This is where the law is strictest and where your accountability matters most.

This chapter covers decisions that **affect individuals**: whom you hire, whom you serve, what you charge, whom you flag, whom you refuse. It is the area of AI use that regulators, employment tribunals and journalists focus on, and the one where the stakes for you are highest.

What counts as an AI-generated decision

You do not need a robot to be "making decisions". A decision is being made by AI whenever a tool's output **determines or heavily shapes** what happens to a person. Examples a small business meets:

- A CV screening tool that scores applicants and hides the low scorers.
- A recruitment platform's "match score" that recruiters follow.
- A fraud filter that blocks a customer's order or account.
- A credit or affordability check that approves or declines a payment plan.
- A scheduling or productivity tool that allocates shifts or flags "underperformers".
- A tool that moderates, bans or restricts a user.
- An insurance or pricing engine that sets a personalised price.

Ask a simple question: *if the tool's answer were different, would a person's outcome be different?* If so, it is a decision about a person, whether a human clicks "confirm" afterwards or not.

The GDPR rule in plain English

Article 22 of the GDPR gives people a right **not to be subject to a decision based solely on automated processing, including profiling, which produces legal effects or similarly significantly affects them**. There are exceptions (for example, where the decision is necessary for a contract, authorised by law or based on explicit consent), but even then you must provide safeguards: at least the right to **obtain human intervention, to express their point of view and to contest the decision**.[14]

Three points trip up small businesses.

"Solely" is narrower than it sounds, but not as narrow as hoped. If a human merely rubber-stamps the tool's output without real influence, regulators treat the decision as automated. This is why Chapter 4 matters: a token human check does not take you outside Article 22.[18]

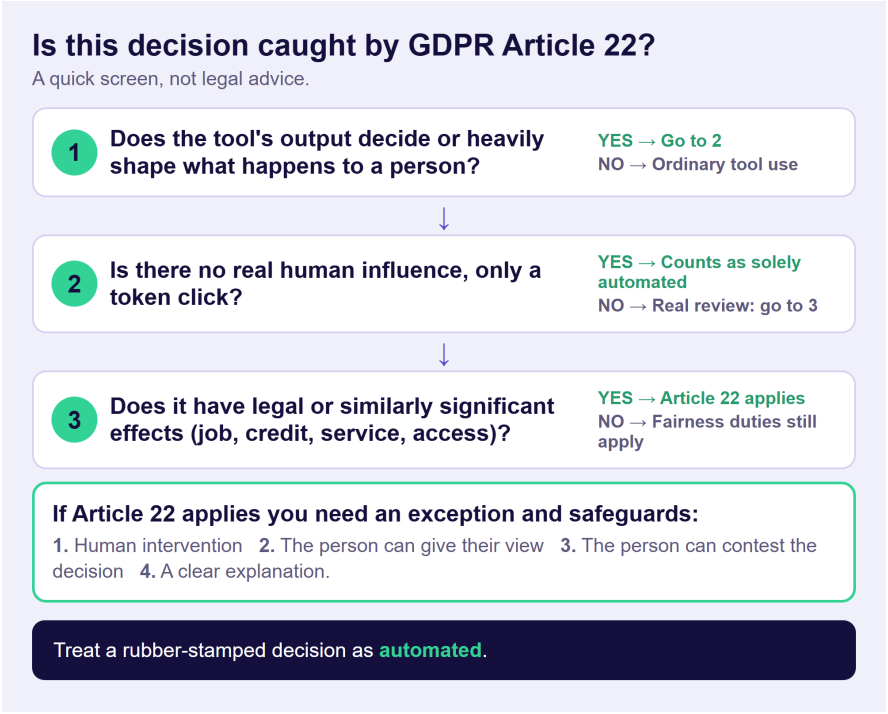
The Court of Justice has read "decision" widely. In the SCHUFA case (December 2023) the Court held that generating a credit score can itself be an automated decision where a third party draws strongly on that score when deciding whether to grant, for example, a loan.[14] If you produce or rely heavily on such scores, you may be inside the rule.

People can ask for an explanation. Articles 13 to 15 require you to give meaningful information about the logic involved in automated decision-making and its significance and consequences.[16] In *Dun & Bradstreet Austria* (February 2025) the Court confirmed that this means explaining the procedure and principles actually applied in a way the person can understand, not simply handing over an algorithm or a formula.[15]

In the UK, the Data (Use and Access) Act 2025 restructured the UK GDPR's rules on automated decision-making, relaxing some restrictions while keeping safeguards for significant decisions and

tightening them where special-category data is used. Check the current UK text if you operate there.[17]

The rule. If an AI-assisted decision materially affects a person, there must be a human who can understand it, explain it and change it.



Is this decision caught by Article 22?

The five duties for any decision about a person

Whether or not Article 22 applies strictly, treat every consequential AI-assisted decision about a person with five duties.

1. Know your legal basis. Under the GDPR you need a lawful basis for using the personal data, and extra conditions for special-category data such as health data. Document it in the register.

2. Tell people. Your privacy notice should say that automated tools are used, for what and with what effect. People should not discover it by being refused.

3. Assess the risk first. Where the processing is likely to result in a high risk to individuals, which includes large-scale profiling and automated decisions with significant effects, a **data protection impact assessment** is required before you start.[19] Even if it is not strictly required, a short written version is excellent evidence.

4. Give a human a real say. A named person with authority reviews the decision, with time and information (CAT-T, Chapter 4), and can override the tool.

5. Offer a route to challenge. Tell the person how to ask for a review, who will do it, and how long it will take. Keep the outcome on record.

Bias: the mistake that hides in the data



Look closely at what the tool is actually weighing

AI trained on past decisions can reproduce the unfairness of those decisions. A screening tool trained on historical hires may prefer the profile of people previously hired. A fraud model may flag customers in certain postcodes more than others. The tool will not announce it.

Discrimination law in most countries asks about the **effect** of a practice, not only the intention behind it. An employer that adopts a tool which disadvantages women, older candidates, disabled people or people from a particular ethnic background may have to justify it.[26]

What you can do as a small deployer:

- **Ask the vendor** what testing it has done for bias, on which groups, and what the results were. Ask for it in writing.
- **Check your own outcomes.** Every quarter, compare pass or approval rates between groups you can reasonably measure. A large unexplained gap is a signal to investigate.
- **Never let the tool be the only judge** of a person's suitability. Keep a human reading the applications that the tool rejected, at least as a sample.
- **Do not feed sensitive attributes** into a tool unless you have a specific, lawful reason and have taken advice.

A real-world warning from the public sector: the Dutch childcare-benefits scandal involved an algorithmic risk system and a tax authority that wrongly accused many families of fraud. The Dutch data-protection authority fined the tax authority for unlawful processing, including the use of nationality in the risk model.[25] Your business is smaller, but the lesson is identical: unchecked automated flags can do real harm to real people, and the organisation is the one held to account.

Explaining a decision to a person

When a customer or applicant asks *why*, "the computer said so" is not an answer. A good explanation has four parts:

1. **What was decided**, in plain words.
2. **The main factors** that led to it, in terms the person can recognise.
3. **What a human did**, including who reviewed it.
4. **How to challenge or correct it**, and what you will do next.

Prepare a template for each high-risk use before you need it. If you cannot explain what the tool did, you should not be using it for that decision.

> **Fictional.** Linden Staffing, a small recruitment agency, used a plug-in that ranked candidates for each vacancy. A candidate who was never shortlisted asked, under the GDPR, why. The consultant opened the tool and could see only a score of 38 out of 100 and a label, "weak fit". She could not say what drove it. Linden contacted the vendor, who could provide only a generic description. The agency suspended the plug-in for shortlisting, moved it to "suggest only" mode, and added a human read of every rejected application for two weeks. In that sample, three well-qualified part-time workers had been scored low because of "gaps" in availability.

Checklist: decisions about people

- ☐ Every AI-assisted decision about a person is listed in the register as **High** risk.
- ☐ We have a lawful basis and have told people in our privacy notice.
- ☐ A short impact assessment exists for each one.
- ☐ A named human can understand and override the decision, and has time to do so.
- ☐ A route to challenge exists and people know about it.
- ☐ We check outcomes by group at least quarterly and act on large gaps.
- ☐ An explanation template exists for each decision type.

CHAPTER 6

Customer Complaints Involving AI

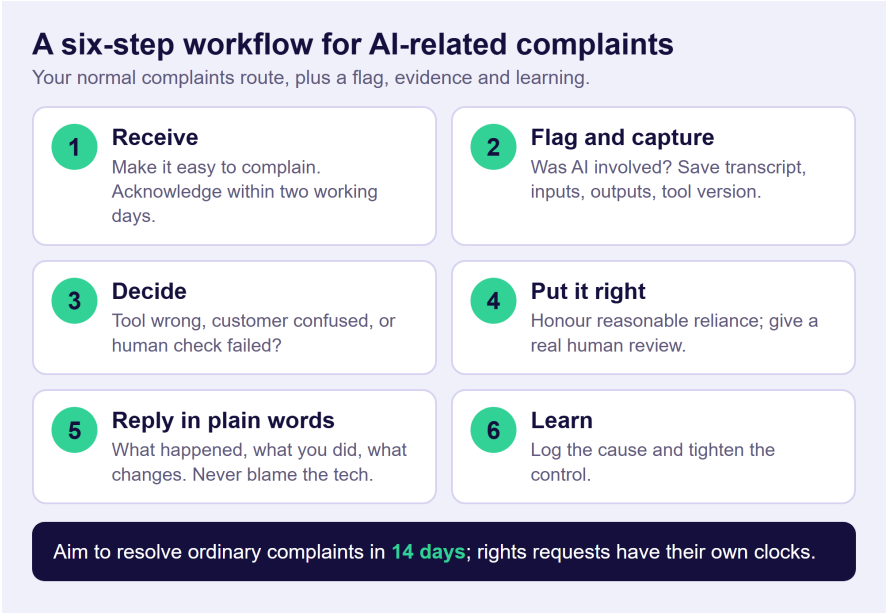


Complaints are where accountability becomes visible. A customer does not care which model, vendor or workflow produced the problem. They care that you said one thing and did another, or that a decision was wrong and nobody would listen.

Handled well, an AI complaint is a cheap lesson and a chance to earn trust. Handled badly, it becomes a refund, a regulator's letter and a social-media post.

Treat AI complaints as ordinary complaints with extra evidence

Do not build a separate, mysterious process for "AI issues". Use your normal complaints route and add three things: a **flag** that AI was involved, an **evidence step** to capture what the tool said or did, and a **learning step** to feed the result back into your controls.



A six-step workflow for AI-related complaints

Step 1. Receive and acknowledge

Make it easy to complain. Put the route on the website, in the chatbot itself and in decision letters. Acknowledge quickly, within a day or two, and say who is handling it and when to expect an answer.

Step 2. Flag and capture the evidence

Ask: *was AI involved?* If yes, **preserve the evidence immediately**: the chat transcript, the screenshot, the input data, the tool's version and settings, the date and time. AI behaviour can change after an update, so what the customer saw may not be reproducible later. This record also protects you if the customer's account turns out to be wrong.

Step 3. Decide what happened

Compare what the tool said or did with your actual policy and the facts. Three outcomes are common:

- **The tool was wrong and the customer relied on it.** Treat it as your statement.
- **The tool was right but the customer misunderstood.** Explain, kindly, and improve the wording.

- **The tool was right, but the decision it informed was wrong.** Review the human check.

Step 4. Put it right

Where the customer relied reasonably on a wrong statement, the default is to honour it or compensate fairly, especially for small sums. The Air Canada claim was about a few hundred dollars; the cost to the airline's reputation was far larger.[1] Arguing that "the chatbot is not us" is unlikely to succeed and is a poor look.

For decisions about people, offer a genuine human review by someone who did not make the original decision, with the right to be heard.

Step 5. Reply in plain words

Say what happened, what you have done about it and what you are changing. Do not blame the technology or the vendor in the customer's reply. They bought from you.

Step 6. Learn and close the loop

Log the complaint, the cause and the fix. If the same type recurs, tighten the control: change the prompt, narrow the tool's scope, add a human check, or switch the tool off for that topic.

Make the chatbot honest about what it is

Whatever the exact timing of the transparency rules, three habits protect you now:

- **Say it is AI.** A short opening line such as "I'm an automated assistant; I can make mistakes" is good practice and, under the AI Act's transparency rules, increasingly expected.[10]
- **Give it limits.** Configure the tool to avoid commitments about refunds, legal rights, health, safety and pricing. For those, it should hand over to a person.
- **Give a way out.** A visible "talk to a person" option, and a rule that it works.

Consider also placing a note on the chat window that official policies are on the relevant page. It will not remove your responsibility, but it helps customers know where the authoritative text lives.

Deadlines, regulators and compensation

Your complaint process sits within wider rights. Customers may go to a consumer body, an alternative dispute resolution scheme, a data-protection authority or a court. The GDPR gives individuals the right to lodge a complaint with a supervisory authority and a right to compensation for material or non-material damage from unlawful processing.[20] Many sectors and countries require businesses to inform customers about out-of-court dispute resolution.[24]

Keep your own clocks. Aim to acknowledge within **two working days** and resolve within **fourteen days** for ordinary complaints, with faster handling for decisions about people. If a data subject makes a rights request (for example, access or an explanation of an automated decision), the GDPR response time is normally one month.

What to record on every AI complaint

- The date, the customer and how they complained.
- The tool involved, and its owner.
- The evidence: transcript, screenshot, inputs, outputs.
- What the policy says, and whether the tool matched it.
- The decision and the remedy.
- The root cause and the change made.
- Whether the case suggests a wider problem (more than one customer, more than one tool).

Appendix E contains a one-page record you can copy.

Fictional. Tidewell Home Goods, from Chapter 1, honoured Willow's 90-day return promise for the one customer and added a line to its chat window: "I'm an automated assistant. For returns, check our policy page or ask for a person." It restricted Willow from stating return periods and linked the policy instead. It logged the complaint, found that Willow's setup had been pasted from a generic template, and ran twenty test questions about returns, delivery and warranty. Four more were wrong. The owner kept the chatbot but reduced its scope and began weekly sampling.

Checklist: complaints

- ☐ Our complaints route covers AI-related issues and is visible on the site and in the chat.
- ☐ Staff know to ask "was AI involved?" and to preserve the evidence.
- ☐ Our default for a reasonable reliance on a wrong AI statement is to put it right.
- ☐ The chatbot says it is automated and can hand over to a person.
- ☐ Every complaint feeds a fix, not just a reply.

CHAPTER 7

Vendors, Contracts and the Blame Game



Most small businesses do not build AI. They buy it, rent it or inherit it inside other software. That makes the supplier contract one of your most important accountability documents, and one of the least read.

The uncomfortable truth is that many AI contracts are written to keep the supplier's risk small and the customer's responsibility large. This chapter helps you read them for what matters.

What the supplier is and is not responsible for

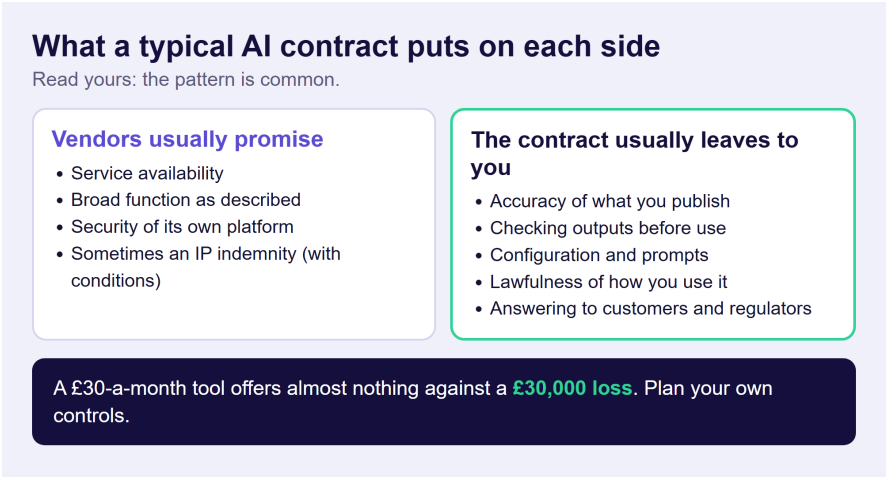


Read the terms before you rely on the tool

Under most AI service terms, the vendor promises that the service will be available and will broadly work as described. It usually does **not** promise that outputs will be accurate, lawful or suitable for your

purpose. Expect language such as "outputs may be inaccurate" and "you are responsible for reviewing outputs". That sentence is the contract version of the rule in this book.

The practical result: if the tool gets something wrong, **the contract will probably say it is on you**, and in a consumer dispute the customer will not be bound by that contract anyway.



What a typical AI contract puts on the vendor and on you

Eight clauses worth reading before you sign

1. Purpose and limits. Is the tool approved for your use? Some vendors prohibit use for employment, credit or medical decisions. Using it that way may breach the terms and cut you off from support.

2. Output disclaimer. What does the vendor say about accuracy? If it says "no warranty", plan the human check accordingly.

3. Data use. Does the vendor use your inputs and outputs to train its models? Can you opt out? Where is the data stored and who can see it?

4. Data-processing agreement. If the tool processes personal data for you, the GDPR requires a written contract with specified terms, including instructions, confidentiality, security, sub-processors and deletion. Article 28 of the GDPR lists what it must contain, and your data-protection adviser or GDPRGard.eu can supply a checklist.

5. Liability cap and exclusions. Look for a cap at, say, twelve months' fees, and exclusions for indirect loss. Know what that means: a £30-a-month tool offers you almost nothing if it causes a £30,000 loss.

6. Indemnities. Some vendors indemnify customers against intellectual-property claims over outputs, usually with conditions. Read the conditions. Few indemnify against accuracy or discrimination claims.

7. Transparency and audit. Will the vendor tell you how the tool works well enough to explain a decision to an individual? Will it give you logs? Will it notify you of material model changes?

8. Incidents, change and exit. How fast will the vendor tell you about incidents? Can you export your data and logs? What happens to them when you leave?

Questions to put to a vendor before you buy

Ask them in writing and keep the answers (Appendix F has the full list).

- What is this tool intended to do, and what is it not intended for?
- How accurate is it, how was that measured, and on what kind of data?
- What testing has been done for bias and harmful outputs?
- Does a human need to review the output, and how do your other customers do it?
- What logs do we receive, and for how long?
- How do you tell us when the model or its behaviour changes?
- Which of our data do you keep, use for training or share, and for how long?
- Who at your company is our contact when something goes wrong?

A vendor that answers clearly is a better risk than one that is vague, however clever its demo.

Who pays? Practical expectations

You will rarely recover your whole loss from a vendor. You are more likely to recover when:

- the fault was clearly a defect in the product, not in your configuration or use;
- the contract includes a meaningful warranty, service credits or indemnity;
- you kept records showing what happened;
- you notified the vendor promptly and in the form the contract requires.

For product defects, the EU's updated product-liability rules are expected to give consumers stronger routes against manufacturers of software and AI from December 2026.[11] They do not replace the need for a good contract, and they do not make you immune from claims by your own customers.

When you configure it, you share the risk

Many tools are configured by you: the prompt, the knowledge base, the tone, the allowed topics, the thresholds. A vendor will say, fairly, that a problem was caused by your setup. Keep a **configuration record**: who changed what, when and why. It protects you in a dispute and helps you debug a failure.

> **The rule.** Assume the contract makes you responsible for outputs. Then make sure your controls would stand up if it did.

Checklist: vendors

- ☐ Each tool in the register has its contract and terms saved.
- ☐ We know what each vendor does with our data.
- ☐ Where personal data is involved, a data-processing agreement is in place.

- ☐ We have asked the vendor the eight questions and filed the answers.
- ☐ We keep a configuration record for tools we set up ourselves.

CHAPTER 8

Governance for Small Businesses



"Governance" sounds like something for banks. For a small business it means only this: **decide in advance who does what, write it down briefly, and check that it happens.** You do not need a committee. You need a clear owner, a short policy and a rhythm.

The smallest framework that works

The framework has six parts. Each can be one page.

1. An accountable owner. One senior person, often the owner or managing director, is accountable for AI use across the business. In a larger firm it might be the COO or head of operations. They do not review everything. They make sure the framework exists.

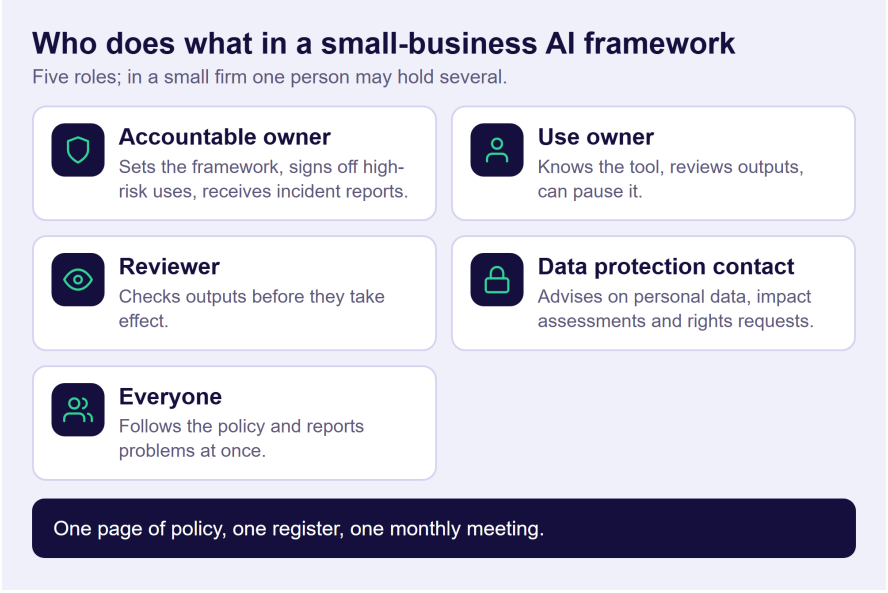
2. Use owners. Each tool in the register has a named person who knows how it is used, who reviews it and who pauses it.

3. A one-page AI policy. What staff may and may not do with AI. Appendix D gives a template.

4. An approval gate. No new AI tool or feature goes live for customers, or touches personal data, until the use owner has completed the one-page accountability check from the start of this book and the register is updated.

5. Training. The AI Act expects organisations to ensure sufficient AI literacy among those who use AI for them.[9] That means short, practical training: how the tools fail, what not to paste in, how to check.

6. A review rhythm. A monthly fifteen-minute meeting, quarterly for stable setups: new tools, incidents, complaints, error rates, vendor changes.



Who does what in a small-business AI framework

What goes in the one-page policy

Keep it short enough to be read. Cover:

- **Approved tools** and how to request a new one.
- **Never paste in:** customer personal data, special-category data, confidential client material, credentials, unreleased financials, unless the tool is approved for it.
- **Always check:** facts, figures, names, quotes, legal or medical statements, and anything sent to a customer.
- **Label:** say when content is AI-generated where honesty or the law requires it.
- **Decisions about people:** never delegated to a tool alone.
- **Report:** tell the owner immediately about an error with external impact, a data leak or a complaint.
- **Consequences:** the policy applies to everyone, including managers.

Make it a living document, with a date and an owner.

Roles in one table

Role	Responsibility	Example
Accountable owner	Sets the framework, signs off high-risk uses, receives incident reports	Managing director
Use owner	Knows the tool, reviews outputs, pauses it	Head of customer service for the chatbot
Reviewer	Checks outputs before they take effect	Duty manager, recruiter
Data protection contact	Advises on personal data, impact assessments, rights requests	DPO or an external adviser
Everyone	Follows the policy and reports problems	All staff

Standards you can borrow, not copy

If you want a structure, two public frameworks are worth knowing. ISO/IEC 42001 sets out a management-system standard for AI, and the US NIST AI Risk Management Framework describes a cycle of governing, mapping, measuring and managing AI risk.[27] A small business does not need certification. But their ideas map closely to the steps in this book, and mentioning them can reassure a larger client who asks what you follow.

Culture beats paperwork

A framework works when people feel safe raising problems. Three habits:

- **Praise the catch.** When someone spots an AI error before it ships, thank them in public.
- **Blame the process, not the person,** when a mistake gets through. Ask *which control failed and how do we fix it?*
- **Leaders go first.** If the owner pastes client data into a free tool, the policy is decoration.

Checklist: governance

- ☐ An accountable owner is named.
- ☐ Every tool in the register has a use owner.
- ☐ The one-page policy is written, dated and shared.
- ☐ No new tool goes live without the approval gate.
- ☐ Staff have had short AI-literacy training, and new joiners get it.
- ☐ A review meeting is in the calendar.

CHAPTER 9

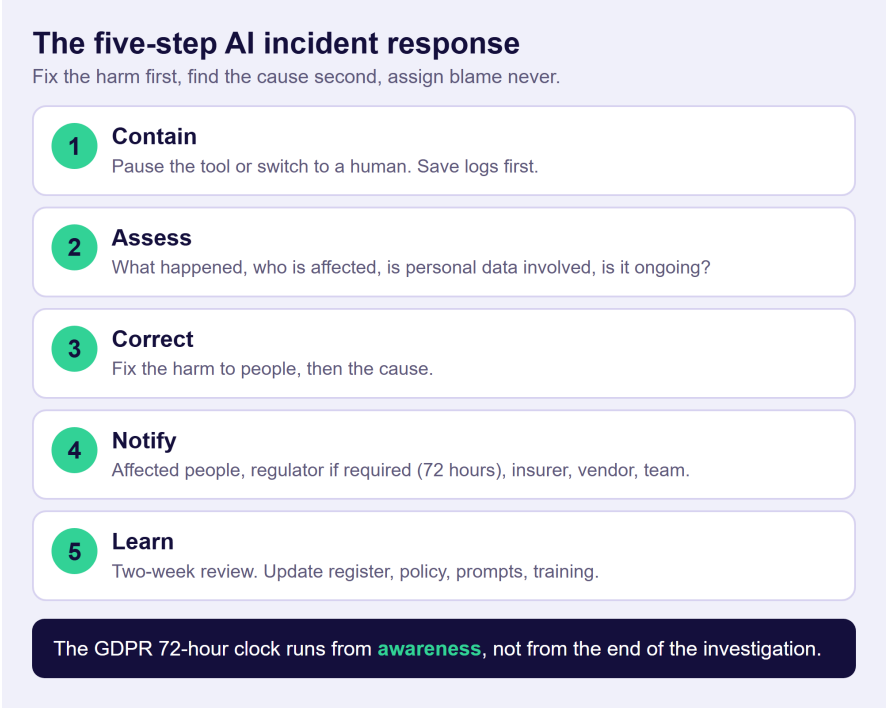
When the AI Gets It Wrong: Incident Response



Controls reduce mistakes. They do not eliminate them. The moment that shows your accountability is not the mistake itself but the hour after you find out about it.

An **AI incident** is any event where an AI tool produced or contributed to a harmful, unlawful or seriously wrong outcome: a false statement to a customer, an unfair decision, a leak of personal data, a fabricated document, a system acting outside its intended limits.

Five steps: Contain, Assess, Correct, Notify, Learn



The five-step AI incident response

1. Contain

Stop the harm spreading. Pause the tool or the feature, switch the chatbot to "hand over to a person", disable the automatic rule or take the affected template offline. Do it first and discuss it afterwards. A paused tool costs a few hours of efficiency; a live faulty tool can cost much more.

Preserve evidence at the same time: save logs, transcripts and settings before anything changes.

2. Assess

Answer five questions, quickly and in writing:

- **What happened,** and what did the tool actually do?
- **Who is affected,** how many, and how badly?
- **Is personal data involved?** Was any disclosed or accessed?

- **Is it still happening?**
- **What is the cause:** the tool, our configuration, our data, a missing human check?

If personal data was exposed or lost, you may have a personal data breach. Under the GDPR, a controller must notify the supervisory authority without undue delay and, where feasible, within **72 hours** of becoming aware, unless the breach is unlikely to result in a risk to people.[23] The clock runs from awareness, not from the end of the investigation. Note that a wrong **answer** is not always a data breach, but sending one customer's data to another is.

3. Correct

Fix the harm to the people affected. Correct the false statement, reverse the unfair decision, reissue the document, apologise sincerely and offer the remedy. For decisions about people, arrange a human review by someone not involved. Then correct the cause: change the configuration, retrain staff, add a check.

4. Notify

Decide who needs to know:

- **The affected people.** Plainly, quickly and with what you are doing.
- **The regulator,** if personal data is involved and the threshold is met.
- **Your insurer,** whose policy may require prompt notice.
- **The vendor,** in the form the contract requires.
- **Partners or clients** who relied on the output.
- **Your team,** so the lesson spreads.

Write the message with a person who will be accountable for it. Do not blame the technology.

5. Learn

Within two weeks, run a short review. Not "who messed up" but "which control would have caught it, and did we have it?" Update the register, the policy, the prompts, the training. Record it in the incident log (Appendix G).

What a good incident record looks like

Field	Example
Date and time found	14 March, 16:20
Tool and owner	Chat assistant, Head of Customer Service
What happened	Quoted a 90-day return period
Who was affected	11 customers in 5 days
Containment	Return topics disabled at 16:45
Cause	Template text copied from another shop; no sampling
Remedy	Honoured the stated period for the 11 customers
Notifications	Customers emailed; insurer informed
Changes made	Policy text locked; weekly 20-chat sample
Owner and date closed	Priya, 28 March

Practise once a year

Run a thirty-minute tabletop. Pick a scenario ("our chatbot has told 50 customers something false; a journalist has called"). Walk through the five steps. Who pauses the tool? Who writes to customers? Who calls the insurer? You will find the gaps in half an hour instead of in a crisis.

> **The rule.** Fix the harm first, find the cause second, assign blame never.

Checklist: incidents

- ☐ We know who can pause each AI tool and how.
- ☐ Everyone knows how to report an AI incident and to whom.
- ☐ A one-page response plan exists using the five steps.
- ☐ We know the 72-hour rule and who decides on regulator notification.
- ☐ We keep an incident log and review it after each event.
- ☐ We have run at least one tabletop exercise.

CHAPTER 10

Records, Evidence and Insurance



When something goes wrong, the businesses that come out best are rarely the ones that never erred. They are the ones that can **show what they did**. A modest, consistent paper trail turns "we think we were careful" into "here is how we were careful".

The evidence file: seven things to keep

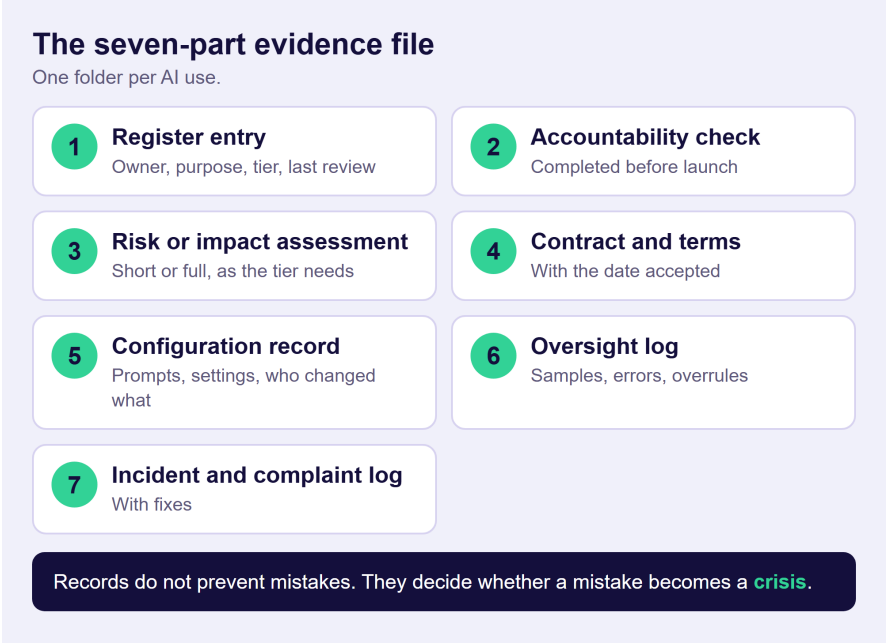


A dated record turns a claim into proof

Keep these in one folder per AI use, or one shared folder with subfolders. Names and dates matter more than polish.

1. **The register entry,** with owner, purpose, risk tier and last review date.
2. **The accountability check,** the one-page questions from the start of this book, completed before launch.

3. **The risk or impact assessment,** short for medium uses, fuller for high-risk uses and where a data protection impact assessment is required.
4. **The contract and terms,** with a note of the date you accepted them, since terms change.
5. **The configuration record:** prompts, settings, thresholds and knowledge-base sources, with who changed what and when.
6. **The oversight log:** samples reviewed, errors found, decisions overruled, reviewer names and dates.
7. **The incident and complaint log,** with fixes.



The seven-part evidence file

Keep logs, with care

Logs show what the tool saw and did. They are your best defence and your best learning source. But logs of chats and decisions often contain personal data, so keep them thoughtfully:

- **Decide a retention period** and follow it. Keep them long enough to cover plausible complaint and claim windows, no longer than needed.
- **Limit access** to the people who need them.
- **Avoid recording more than you need,** particularly sensitive data.
- **Make sure you can retrieve them** by date and customer, to answer a complaint or a rights request.

The AI Act expects deployers of high-risk systems to keep logs automatically generated by the system for an appropriate period, at least six months unless other law says otherwise. Aim for something similar for your higher-risk uses.[21]

Records of what you told people

Keep copies of the text of your chatbot's opening message, your policy pages and your AI notices, with dates. If a customer says the site said something, you can show what it said on that day.

Insurance: ask before you need it

AI risk does not fit neatly into traditional policies. Some policies cover mistakes in professional advice, some cover cyber events, some cover neither when AI is involved. Insurers are beginning to ask about AI use and some are adding exclusions or conditions.

Do three things:

1. **Read your policies** (professional indemnity, cyber, public liability, directors' and officers') for exclusions mentioning "automated", "algorithmic" or "artificial intelligence".
2. **Ask your broker in writing:** "Is a loss arising from an error by an AI tool we use covered? Is there a notification duty? Are there conditions about human review?"
3. **Tell the insurer what you do.** A short summary of your register, human review and policy is often welcomed and can support better terms.

Where a policy requires you to notify circumstances promptly, add the insurer to your incident checklist.

> **The rule.** Records do not prevent mistakes. They decide whether a mistake becomes a crisis.

Checklist: records and insurance

- ☐ Each AI use has an evidence folder with the seven items.
- ☐ Logs are kept for a defined period, with controlled access.
- ☐ We keep dated copies of AI notices and policy pages.
- ☐ We have asked our broker about AI-related cover in writing.
- ☐ The insurer is on our incident notification list.

CHAPTER 11

Your 30-Day AI Accountability Plan



You can put the essentials in place in a month, working a few hours a week. Here is one way to do it. Adjust the pace to your size.

Four weeks to a defensible position

A few hours a week.

Week 1 SEE	Week 2 CONTROL	Week 3 PREPARE	Week 4 PROVE
☐ Survey AI use	☐ Human checks	☐ Complaint route	☐ Tabletop drill
☐ Build the register	☐ Chat wording	☐ Incident plan	☐ Staff training
☐ Tier every use	☐ Privacy notice	☐ Off switches	☐ Evidence files
☐ Name the owner	☐ One-page policy	☐ Vendor questions	☐ Insurance query

By day 30: a register, owners, real oversight, a policy, a response plan and an evidence file.

Four weeks to a defensible position

Week 1: See

- ☐ Ask staff, team leads and IT about every AI tool and AI feature, including free ones.
- ☐ Build the register (Appendix A) with a named owner for each use.
- ☐ Assign a risk tier to each use (Appendix B).
- ☐ Name the accountable owner.
- ☐ Switch off or restrict anything you cannot explain and that affects customers or people.

Output: a complete register and a list of the top three risks.

Week 2: Control

- ☐ For each high-risk use, name the human decision-maker and test them against CAT-T.
- ☐ Add a human check or sampling routine to each medium-risk use.
- ☐ Add "I'm an automated assistant" wording and a human hand-over to customer-facing chat.
- ☐ Check your privacy notice mentions AI use and automated decisions where relevant.
- ☐ Write the one-page AI policy (Appendix D) and share it.

Output: oversight on every use that needs it, and a published policy.

Week 3: Prepare

- ☐ Add "was AI involved?" to your complaints process and create the complaint record (Appendix E).
- ☐ Write the five-step incident plan and the incident log (Appendix G).
- ☐ Name who can pause each tool, and test it.
- ☐ Send the vendor questionnaire (Appendix F) to your three most important AI suppliers.
- ☐ Read the liability and data clauses of those contracts.

Output: a tested response plan and vendor answers on file.

Week 4: Prove

- ☐ Run a thirty-minute tabletop exercise on one scenario.
- ☐ Deliver short AI-literacy training to all staff.
- ☐ Build the evidence folder for each high-risk use.
- ☐ Ask your broker about AI-related cover.
- ☐ Book the monthly review meeting and the first quarterly review.

Output: trained staff, rehearsed response, an evidence file and a rhythm.

After day 30

- Review the register monthly, the high-risk uses quarterly and the whole framework at least yearly.
- Re-check the law at each review. The AI Act dates, the product-liability rules and national guidance are moving.
- Retire tools you no longer need. Every unused AI tool is a risk with no benefit.

One page for the board, or yourself

At the end of the month, summarise in five lines: how many AI uses, how many high-risk, what controls exist, what incidents and complaints occurred, and what you will do next quarter. If you cannot write it, you are not done. If you can, you are ahead of most.

CHAPTER 12

Five Case Files



> **Fictional.** Every business and person below is invented. Use the cases to practise: read the facts, answer the questions, then compare your answers with the notes.

Case 1: The generous chatbot (Tidewell Home Goods)

Facts. A chatbot tells a customer she can return an item after 90 days. The policy is 30. The customer returns it, pays shipping, and is refused a refund. She posts the screenshot.

Questions. Is the business bound? Who should have owned the chatbot's content? What control was missing?

Notes. The business is likely to be treated as having made the statement. The use owner should have been the head of customer service. The missing controls were scope limits (no refund terms in the chat), sampling and a hand-over. Honour the promise, fix the setup, log the incident.

Case 2: The invisible screen (Linden Staffing)

Facts. A recruitment plug-in scores candidates. Recruiters shortlist from the top ten. A rejected candidate asks why.

Questions. Is this an automated decision? What can the agency explain? What should it have asked the vendor?

Notes. Recruiters rely heavily on the score, so Article 22 may apply and the agency needs a real human review. It should have asked about testing for bias, how the score is built and what logs it gets. Interim fix:

suggest-only mode, sampling of rejections, an explanation template.

Case 3: The confident letter (Marlow & Pike Accountants)

Facts. A junior accountant uses an AI tool to draft a client letter on tax relief. It cites a relief that does not apply. The client acts on it and pays a penalty.

Questions. Who is responsible to the client? What oversight should apply to professional advice? Does insurance respond?

Notes. The firm owes the client a duty of care; the tool is no defence. Advice letters are high-risk: a qualified reviewer must check every claim against primary sources. Check the professional indemnity policy for AI conditions and notify promptly.

Case 4: The silent flag (Bright Lane Pets)

Facts. A payment fraud filter blocks about 3% of orders. Customers in some regions are blocked more than others. No one reviews the blocks.

Questions. Is it a decision about people? What is missing? What should the shop measure?

Notes. Blocking customers can significantly affect them, so treat it as high-risk. Add a human review queue for blocks, a way for customers to contest, and a monthly check of block rates by region and a sample of false positives.

Case 5: The helpful assistant (Oakridge Dental)

Facts. A receptionist pastes patient emails into a free AI tool to draft replies. The emails contain health details. A patient later learns of it.

Questions. What law is engaged? Is it an AI incident? What would you do first?

Notes. Health data is special-category data. Sending it to an unapproved tool may be a personal data breach and breach the GDPR's principles. Contain (stop the practice, delete what you can), assess the

breach and the 72-hour clock, notify as needed, then provide an approved tool and training.

Conclusion: Answerable



Somewhere in your business right now, an AI tool is producing something a person will rely on. It may be right a hundred times in a row. On the hundred and first, the question this book began with will arrive: **who is responsible?**

If you have followed the steps, the answer is not a shrug. It is a name, a record and a plan. You know where the tool is used. Someone owns it. A competent human checks what matters. Customers can complain, and are heard. Contracts say what they say, and you have read them. When something slips, you contain it, fix it, tell the right people and learn.

That is not perfection, and the law does not require perfection. It is accountability: the ability to say what you did, why you did it, and what you did next.

AI will keep changing. Rules will be delayed, amended and clarified. Tools will get better and strange in new ways. But the principle at the centre of this book will outlast all of it: **a tool can assist, but a person answers.**

Be that person on purpose.

APPENDIX A

AI Use Register

Copy one row per AI use. Review monthly.

#	Tool and supplier	Purpose and output	Who sees it	Personal data	Owner	Human check	Tier
1							
2							
3							
4							
5							
6							

APPENDIX B

Decision Risk Sheet

Complete one for each new use. If any answer in the "High" column is yes, treat the use as High risk.

Question	Low	Medium	High (yes?)
Who is affected?	Staff only	Customers	Individuals' jobs, money, health, rights
Is the output reviewed by a human first?	Always	Sampled	Never or token
Can a mistake be reversed?	Easily	With effort	Hardly or never
Is special-category or children's data used?	No	Ordinary personal data	Yes
Is it a decision about a person?	No	Informs	Determines
Is the tool in an AI Act high-risk area (e.g., recruitment, credit)?	No	Unsure	Yes

Tier: _____ **Owner:** _____ **Date:** _____ **Next review:** _____

APPENDIX C

Human Review Log

Use for sampling and for high-risk reviews.

Date	Tool	Reviewer	Item or case	Correct? Y/N	Action taken	Notes

Error rate this month: _____ of _____ reviewed (_____ %). **Trend:** better / same / worse.

APPENDIX D

One-Page AI Policy Template

[Business name] AI Use Policy. Owner: _____ Date: _____ Review: _____

1. **Purpose.** AI tools can help us work faster. This policy explains how we use them responsibly, because we remain accountable for everything we send, decide or publish.
2. **Approved tools.** Only tools on the AI use register may be used for work. To request a new tool, ask _____.
3. **Never paste in** customer personal data, health data, children's data, confidential client material, passwords or unpublished financial information, unless the tool is approved for that purpose.
4. **Always check** facts, figures, names, quotations, legal, medical and financial statements and anything that goes to a customer or the public. AI output is a draft.
5. **Decisions about people** (hiring, pay, discipline, credit, access, refusals) are never made by an AI tool alone. A named human decides.
6. **Transparency.** We tell customers when they are talking to an automated assistant, and we label AI-generated content where honesty or the law requires.
7. **Reporting.** Tell _____ at once about an AI error with external impact, a data leak or a complaint involving AI.
8. **Training.** Everyone who uses AI at work completes our short AI-literacy training.
9. **Responsibility.** The person who uses or approves an output is responsible for checking it. Managers are responsible for the tools in their area.
0. **Review.** We review this policy at least yearly.

Signed: _____ Date: _____

APPENDIX E

AI Complaint Record

Field	Details
Date received / how	
Customer or person	
What they say happened	
Was AI involved? Which tool?	
Evidence saved (transcript, screenshot, inputs, outputs)	
What our policy says	
Finding: tool wrong / customer misunderstood / human check failed	
Remedy offered and date	
Human reviewer (if a decision about a person)	
Root cause	
Fix and owner	
Wider risk? Other customers or tools	
Closed on	

APPENDIX F

AI Vendor Questionnaire

Send to each AI supplier and file the answers.

Purpose and fit

- What is the tool intended for, and what uses do you exclude?
- Is it suitable for decisions about people, or for health, legal or financial advice?

Accuracy and testing

- How is accuracy measured, and what are the current results?
- What testing has been done for bias, harmful outputs and misuse?
- What known limitations should a customer plan for?

Data

- Which of our data do you store, and where?
- Do you use our inputs or outputs to train models? Can we opt out?
- Who are your sub-processors? Do you have a data-processing agreement?
- How long do you keep data, and how is it deleted?

Transparency and logs

- What logs and explanations can we obtain for a specific output or decision?
- How will you notify us of changes to the model or its behaviour?

Incidents and liability

- How quickly will you notify us of an incident?
- What is your liability cap, and what do you indemnify?
- Which regulatory duties (such as the AI Act) do you say apply to you, and which to us?

Exit

- Can we export our data and logs? In what format? What happens on termination?

APPENDIX G

AI Incident Log

Date found	Tool	What happened	Who was affected	Contained (when, how)	Cause and remedy	Notified (who)	Owner and closed

Glossary

Accountability. Being able to show who decided what, why, and what was done when it went wrong.

AI literacy. The skills, knowledge and understanding that let staff use AI systems competently and be aware of their opportunities and risks. An AI Act requirement for providers and deployers.

Article 22 (GDPR). The provision giving people protections against decisions based solely on automated processing that have legal or similarly significant effects.

Automation bias. The tendency to over-rely on an automated suggestion and to miss its errors.

Controller. The organisation that decides why and how personal data is processed.

Data protection impact assessment (DPIA). A structured risk assessment required for processing likely to result in a high risk to individuals.

Deployer. Under the AI Act, an organisation that uses an AI system under its own authority in a professional capacity.

Hallucination. An output that is fluent and confident but false or invented.

High-risk AI system. Under the AI Act, an AI system in a listed area, such as recruitment, worker management, credit scoring or essential services, which carries stricter duties.

Human in the loop. A person reviews and approves each output before it takes effect.

Human on the loop. A person monitors and samples an automated process and can intervene.

Profiling. Automated processing of personal data to evaluate aspects of a person, such as performance, reliability or behaviour.

Provider. Under the AI Act, an organisation that develops an AI system or has one developed and places it on the market.

Shadow AI. AI tools that staff use without the organisation's knowledge or approval.

Special-category data. Sensitive personal data such as health, ethnicity, religion or biometric data, with stronger protection under the GDPR.

A Note on GDPRGard.eu

Accountability for AI sits beside a wider question: what does the GDPR expect of a small business? If this book has raised questions about records of processing, impact assessments, data-subject requests or breach reporting, **GDPRGard.eu** offers free tools, guides and articles written in plain English for small organisations.

About the Author

Zirlandia Milkovic writes practical, plain-English guides on data protection, AI and building a business with confidence. She believes privacy is not a barrier to ambition but a foundation of trust, and that business owners should not need a legal degree to understand the rules that apply to them.

She is the author of a series of business guides, including *GDPR Made Simple for Women Founders*, and her work focuses on turning complex European rules into simple steps, checklists and templates that busy people can actually use. She is also behind **GDPRGard**, a growing collection of free GDPR tools, guides and articles for small businesses, available at gdprgard.eu.

Visit **gdprgard.eu** for free tools, articles and updates, including notes on changes to the rules covered in this book. If this guide helped you, an honest review where you bought it helps other readers find it.

Notes and Sources

Research cut-off: 30 October 2026. Items marked (read) were consulted for this edition; the others rest on the author's working knowledge of well-known public records and should be re-checked against the primary source before you rely on them.

1. Moffatt v. Air Canada, 2024 BCCRT 149 (British Columbia Civil Resolution Tribunal, 14 February 2024) (read, through secondary commentary). decisions.civilresolutionbc.ca.
2. Public reporting on the DPD customer-service chatbot incident, January 2024, including the company's statement that it had disabled the AI element.
3. Public reporting on the Chevrolet of Watsonville chatbot prompts, December 2023.
4. Mata v. Avianca, Inc., US District Court, Southern District of New York, sanctions order of June 2023.
5. Public reporting on the partial refund by Deloitte Australia to the Department of Employment and Workplace Relations over an AI-affected report, October 2025.
6. GDPR (Regulation (EU) 2016/679), Articles 4(7), 5(2) and 24. eur-lex.europa.eu.
7. Regulation (EU) 2024/1689 (AI Act), Article 3 (definitions of provider and deployer) and Article 26 (obligations of deployers of high-risk AI systems). eur-lex.europa.eu.
8. Regulation (EU) 2026/1744 amending the AI Act ("AI Omnibus"), published in the Official Journal on 24 July 2026 and in force from 27 July 2026; high-risk dates of 2 December 2027 and 2 August 2028 (read, through law-firm and trade commentary; the Official Journal text should be checked).
9. AI Act, Article 4 (AI literacy), applicable from 2 February 2025.
10. AI Act, Article 50 (transparency obligations for certain AI systems). Secondary sources differ on application dates after the Omnibus; check the final text.
11. Directive (EU) 2024/2853 on liability for defective products; transposition deadline 9 December 2026 (read, through secondary commentary).
12. European Commission decision to withdraw the proposed AI Liability Directive, announced in its 2025 work programme.
13. Consumer Rights Act 2015 (UK), sections 49 and 50; Directive 2005/29/EC (unfair commercial practices); Directive 2011/83/EU (consumer rights).

14. GDPR Article 22; Court of Justice of the EU, Case C-634/21, SCHUFA Holding (Scoring), 7 December 2023.
15. Court of Justice of the EU, Case C-203/22, Dun & Bradstreet Austria, 27 February 2025.
16. GDPR Articles 13(2)(f), 14(2)(g) and 15(1)(h).
17. Data (Use and Access) Act 2025 (UK), amendments to the UK GDPR on automated decision-making (Articles 22A to 22D).
18. Article 29 Working Party, Guidelines on Automated individual decision-making and Profiling (WP251 rev.01), endorsed by the EDPB.
19. GDPR Article 35 and Article 9.
20. GDPR Articles 77, 78 and 82.
21. AI Act, Articles 14 (human oversight), 26 (deployer obligations, including assigning human oversight to competent persons and keeping logs for at least six months) and 12 (record-keeping).
22. Parasuraman, R. and Manzey, D., "Complacency and Bias in Human Use of Automation: An Attentional Integration", Human Factors, 2010.
23. GDPR Articles 33 and 34; EDPB Guidelines 9/2022 on personal data breach notification.
24. Directive 2013/11/EU on alternative dispute resolution for consumer disputes.
25. Autoriteit Persoonsgegevens (Dutch DPA), decision and fine against the Tax and Customs Administration in the childcare-benefits matter (fine announced December 2021).
26. Equal-treatment law, including Directive 2000/78/EC and the UK Equality Act 2010, on indirect discrimination.
27. ISO/IEC 42001:2023 (AI management systems); NIST, Artificial Intelligence Risk Management Framework (AI RMF 1.0), 2023.